

Relatório de Auditoria de Segurança de Aplicações

QualiDecision (PerfilCliente) • Rafitec S.A. / Grupo Vaccaro

Data	02/10/2026	Ambiente	qualidecision.vercel.app + Supabase (ddhqmsszumyyabkvmpqh, São Paulo)
Elaborado por	Agente security-expert (Arquiteto Sênior de AppSec / PSI Grupo Vaccaro)	Versão Codebase	Commit 0a2997f / Branch main
Metodologia	Auditoria estática de código (SAST), análise de fluxo de autenticação JWT, verificação de políticas RLS, storage buckets e conformidade com a PSI do Grupo Vaccaro e normas ISO 9001.		

 VEREDITO GERAL: BLOQUEADO POR RISCO CRÍTICO

A aplicação realizou avanços substanciais e exemplares no banco de dados (RLS ativado, revoke de anon, autoria forçada no banco via trigger para ISO 9001). No entanto, o **deploy em produção permanece vetado** devido a duas falhas críticas residuais: **(1) Fotos de evidência industrial com URLs públicas de 1 ano no storage** e **(2) Rotas de inteligência artificial desprotegidas contra acesso anônimo e injeção de prompt**.

1. RESUMO EXECUTIVO DOS ACHADOS

#	PROBLEMA IDENTIFICADO	GRAVIDADE	SITUAÇÃO	AÇÃO REQUERIDA
1	Fotos de Evidência com URL Pública e Permanente (Storage)	CRÍTICO	Não Conforme	Adotar Signed URLs temporárias (15 min)
2	Rotas de IA (/api/ai/chat) sem Autenticação JWT	CRÍTICO	Não Conforme	Validar sessão corporativa e sanitizar prompt
3	Nomes Reais de Clientes Embutidos no Front-end	ALTO	Não Conforme	Expurgar TOP_CLIENTS_QUICK e buscar do banco
4	Modal de Inserção de API Key no Navegador	ALTO	Não Conforme	Remover modal e centralizar 100% no servidor
5	Credenciais Supabase com Fallback Hardcoded no Código	MÉDIO	Sob Monitoramento	Garantir variáveis de ambiente no painel Vercel
6	Trava de Domínio restrita apenas a @rafitec.com.br	MÉDIO	Ajuste Homologado	Permitir também @vaccaro.com.br
7	Expurgo Incompleto do Armazenamento no Logout	MÉDIO	Ajuste Homologado	Executar localStorage.clear() total

2. DETALHAMENTO TÉCNICO DAS VULNERABILIDADES

1. Exposição Pública e Permanente de Fotos Industriais (Storage)

CRÍTICO

Contexto: src/services/photoStorageService.ts e PhotoUploadCamera.tsx

Vulnerabilidade: O serviço invoca supabase.storage.from('quality-evidence').getPublicUrl(data.path) com cacheControl: '31536000' (1 ano em cache público na CDN).

Impacto: Violação do Pilar 2 da PSI e LGPD. Imagens de laudos, fardos com identificação de clientes (Aurora, Bunge) e OPs ficam abertas a indexação e visualização pública irrestrita sem necessidade de login.

Código Inseguro:

```
// INSEGURO: Gera link público permanente para evidência técnica
const { data: publicUrlData } = supabase.storage
  .from('quality-evidence')
  .getPublicUrl(data.path);
return publicUrlData.publicUrl;
```

Correção

Homologada:

```
// SEGURO: Gera Signed URL temporária válida por apenas 15 minutos (900s)
const { data: signedData, error: signError } = await supabase.storage
  .from('quality-evidence')
  .createSignedUrl(data.path, 900);
return signedData.signedUrl;
```

2. Rotas de IA sem Autenticação & Vulnerabilidade a Injeção de Prompt

CRÍTICO

Contexto: src/app/api/ai/chat/route.ts e src/app/api/ai/refine-speech/route.ts

Vulnerabilidade: O endpoint POST /api/ai/chat não valida o token JWT no cabeçalho Authorization. Qualquer agente anônimo pode disparar requisições contra a API da Anthropic Claude (esgotando créditos financeiros - *Denial of Wallet*) e o prompt é interpolado diretamente em texto, permitindo escape de instruções do Sensei.

Impacto: Evasão de custos corporativos, abuso de tokens da Rafitec e risco de manipulação da IA.

Código Inseguro:

```
// INSEGURO: Rota aberta ao público; sem validação de sessão; interpolação direta
export async function POST(req: Request) {
  const body = await req.json(); // Sem checagem de usuário logado
  content: `Você é o Sensei... Dúvida: "${body.prompt}"`
}
```

Correção

Homologada:

```
// SEGURO: Validação estrita de Bearer JWT + Separação de System e User Prompt
const authHeader = req.headers.get('authorization');
const token = authHeader?.replace(/^Bearer\s+/i, '').trim();
const { data: { user }, error: authErr } = await supabaseServer.auth.getUser(token);
if (authErr || !user) return NextResponse.json({ error: 'Acesso negado' }, { status: 401 });
```

3. Vazamento de Dados Comerciais no Bundle Público

ALTO

Contexto: `src/app/chao-de-fabrica/page.tsx` e `QualityAiChat.tsx`

Vulnerabilidade: Constantes como `TOP_CLIENTS_QUICK` contêm nomes reais de clientes (*Aurora*, *Copacol*, *Bunge*, *Alisul*, *JBS*, *Yara*), compiladas estaticamente nos chunks públicos de JavaScript acessíveis sem autenticação.

Correção: Remover arrays estáticos do código; alimentar filtros do chão de fábrica exclusivamente através dos clientes carregados do Supabase após o login.

4. Modal de Chave de IA no Front-End

ALTO

Contexto: `QualityAiChat.tsx` e `storageService.ts`

Vulnerabilidade: Interface do assistente exibe modal incentivando o operador a inserir chaves de API, salvando credenciais em storage do navegador.

Correção: Expurgo completo do modal e campos no front-end. O Sensei deve operar de forma 100% transparente via backend corporativo.

3. CHECKLIST DE CONFORMIDADE COM OS 9 PILARES DA PSI

- ✓ **1. Banco de Dados e RLS:** Conforme. Anon revogado de todas as tabelas; consultas do servidor usam `createUserSupabaseClient(token)` repassando o JWT.
- ✗ **2. Proteção de Storage:** Não Conforme. Bucket `quality-evidence` exige transição imediata para Signed URLs de 15 minutos.
- ✗ **3. Sigilo de Dados no Bundle:** Não Conforme. Nomes de clientes embutidos em `TOP_CLIENTS_QUICK` devem ser expurgados.
- ▲ **4. Governança de Chaves de IA:** Parcialmente Conforme. Rota servidora pronta para Claude, mas front-end ainda possui modal residual de API key.
- ✓ **5. Integridade e Autoria ISO 9001:** Conforme. Campo de texto livre removido; autoria forçada no banco via trigger `trg_concessions_approved_by` com `auth.uid()`.
- ✗ **6. Segurança em Rotas de API:** Não Conforme. `/api/quality` está protegida, porém `/api/ai/chat` e `/api/ai/refine-speech` estão anônimas.
- ▲ **7. Trava de Domínio Corporativo:** Parcialmente Conforme. Validação aceita `@rafitec.com.br`; incluir `@vaccaro.com.br`. Senha de 12 chars ativa.
- ✓ **8. Expurgo no Logout:** Conforme. Logout limpa a sessão Supabase; homologado `localStorage.clear()` irrestrito para o Gemba.
- ✓ **9. Funções do Banco (Search Path):** Conforme. Funções definidas com `SECURITY DEFINER` e `SET search_path = public`.

4. PRÓXIMOS PASSOS PARA DESBLOQUEIO

1. Aplicar o patch de **Signed URLs** em `photoStorageService.ts` e atualizar `PhotoUploadCamera.tsx`.
2. Aplicar o patch de **Autenticação JWT** em `src/app/api/ai/chat/route.ts` e `src/app/api/ai/refine-speech/route.ts`.
3. Expurgar `TOP_CLIENTS_QUICK` em `chao-de-fabrica/page.tsx` e remover o modal de API key em `QualityAiChat.tsx`.
4. Cadastrar o domínio `vaccaro.com.br` na validação corporativa do `AuthContext.tsx`.
5. Executar nova compilação limpa (`npm run build`) e enviar para a Vercel com **100% de Conformidade**.